



IDS e agenti sulle macchine

Riconoscere che qualcosa è cambiato in un modo che riguarda la sicurezza, e vedere dall'interno ciò che dalla rete non si vede. Nessuno chiama indietro.

13/09/2026 14:42

Riconoscere che qualcosa è cambiato in un modo che riguarda la sicurezza, e vedere dall'interno ciò che dalla rete non si vede. Nessuno chiama indietro.

Riferimenti	
Sorgente	17_IDS_E_AGENTI.md
Prodotto	snap - Secure Network Assessment Platform

Contenuto del documento
1. Scopo e portata
2. Riferimenti
3. Decisioni assunte
4. Architettura
5. Catalogo delle regole (prima serie)
6. L'agente di macchina
7. Requisiti
8. Privacy e conformità
9. Come si legge: sei casi
10. Limiti dichiarati

Documento generato dal sorgente in docs/: se il contenuto cambia, cambia il sorgente e questo PDF si rigenera. Una copia modificata a mano sarebbe una seconda verità'.

13/09/2026 14:42 · periodo di riferimento: documentazione di prodotto

DOCUMENTO	RILEVAZIONE DELLE INTRUSIONI (IDS) E AGENTI DI MACCHINA
Versione documentata	console 1.7.6, sonda 1.2.6, agente 1.0.2
Conformità	ISO/IEC/IEEE 29148:2018 (§1 scopo, §2 riferimenti, §3 requisiti), NIS2 art. 21, CRA all. I
Aggiornato	2026-09-13

1. Scopo e portata

Il prodotto sa che cosa c'è in rete e se risponde. Questo documento aggiunge due cose che oggi mancano:

- 1. l'IDS: riconoscere che qualcosa è cambiato in un modo che riguarda la sicurezza — un indirizzo che cambia scheda di rete, una porta di amministrazione comparsa dove non c'era, un apparato mai visto in rete alle tre di notte;
- 2. l'agente di macchina: portare dentro il sistema quello che dall'esterno non si può vedere — chi ha provato ad accedere, quale processo tiene aperta una porta, se il disco sta finendo, se il servizio di sicurezza è stato fermato.

Non sono due funzioni separate: l'agente è il sensore più informato dell'IDS. Una porta 4444 aperta vista dalla rete è una porta aperta; vista dall'agente è nc.exe avviato dall'utente mrossi dieci minuti fa.

Che cosa questo IDS è, e che cosa non è

È un motore di rilevazione su osservazione: confronta ciò che la sonda e gli agenti vedono adesso con ciò che era normale prima, e applica un catalogo di regole dichiarate.

Non è un NIDS che ispeziona il traffico: non vede i pacchetti, quindi non riconosce un exploit nel payload, un canale di comando cifrato o un'esfiltrazione.

Questo limite è dichiarato in ogni pagina che mostra rilevazioni. Un prodotto che lasciasse credere il contrario sarebbe peggio di uno che non rileva niente: darebbe una sicurezza che non ha.

L'architettura però non lo esclude. I sensori sono innestabili (§4.2): aggiungere un sensore di traffico domani significa scrivere una classe, non rifare il motore.

2. Riferimenti

DOCUMENTO	CHE COSA NE SERVE QUI
03_PROTOCOLLO_SNAP_SEC.md	La direzione delle connessioni: chi sta più in basso apre verso chi sta più in alto. L'agente segue la stessa regola
06_INVENTARIO_E_MONITOR.md	Le osservazioni su cui lavora il sensore d'inventario
11_SALA_OPERATIVA.md	Dove finiscono le rilevazioni nel turno di chi guarda
14_MOTORE_DI_SCANSIONE.md	Le fasi che producono le osservazioni
MITRE ATT&CK	Ogni regola dichiara la tecnica che riconosce

3. Decisioni assunte

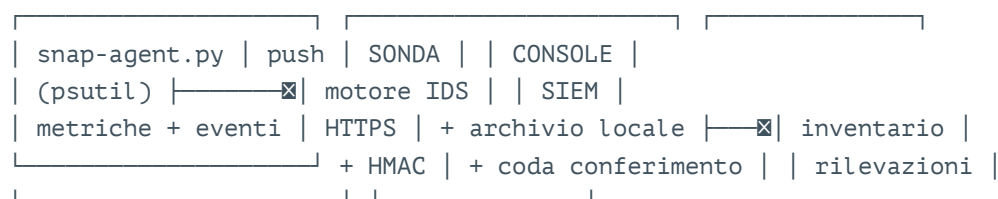
ID	DECISIONE	PERCHÉ
I D S -	Il motore gira sulla sonda, non sul server	La sonda è l'unica a contatto con la rete sorvegliata; il server non la raggiunge nemmeno. Rilevare sul server significherebbe rilevare in ritardo, su dati già conferiti
I D S -	Le rilevazioni conferite entrano nel SIEM esistente come eventi, non in un impianto parallelo	Il server ha già regole a soglia, allarmi che si aggiornano invece di duplicarsi e tecniche MITRE. Un secondo impianto avrebbe voluto dire due posti in cui guardare e due verità
I D S -	Ogni regola dichiara codice, gravità, tecnica MITRE e il perché	Una rilevazione senza il motivo è un allarme che si impara a ignorare
I D S -	Il confronto è con una linea di base che si costruisce da sola, e che dichiara da quando esiste	Rilevare "porta nuova" al primo giro significherebbe segnalare l'intera rete. Finché la linea di base è giovane, le rilevazioni si contano ma non si allarmano

ID	DECISIONE	PERCHÉ
I D S - 0 1	Oltre alla maturità del singolo soggetto vale quella dell'intero archivio: finché la memoria complessiva è più giovane della soglia, le regole che si fondano sull'assenza di memoria non scattano	Imparata sul campo. Un soggetto appena visto non ha memoria per definizione, quindi la sola maturità per soggetto non ferma niente: alla prima passata su una rete vera sono uscite quattrocento rilevazioni HOST-NUOVO in un colpo. Un IDS che al primo avvio segnala l'intera rete viene disattivato il giorno dopo
I D S -	I sensori sono innestabili e ciascuno dichiara di che cosa è capace	È la porta lasciata aperta per il traffico, senza prometterlo oggi
A G - 0 1	L'agente apre lui la connessione verso la sonda	Stessa regola della sonda verso il server: una macchina in una rete di utenza non è raggiungibile, e non deve esserlo
A G - 0 2	L'agente si autentica con una chiave propria, emessa alla registrazione, e firma ogni invio (HMAC-SHA256 con marca temporale e nonce)	Senza firma, chiunque sulla rete potrebbe iniettare metriche false e far scattare o tacere le regole
A G - 0 3	L'agente non riceve comandi in questa versione: riceve solo la propria configurazione nella risposta	Un agente che esegue comandi è un canale di esecuzione remota su ogni macchina sorvegliata: si aggiunge quando serve davvero, con la stessa cura del protocollo delle sonde
A G - 0 4	Una sola dipendenza (psutil), dichiarata	Le stesse metriche su Windows e Linux senza scrivere due volte il codice di raccolta. È mantenuta, diffusa e va nell'SBOM
A G - 0 6	Un evento che descrive una condizione (disco pieno, protezione ferma, accessi falliti) si riferisce quando lo stato cambia di fascia, e si riarma dopo sei ore	Imparata sul campo, come IDS-06. Alla prima prova su una macchina vera sono arrivati centootto eventi disco_pieno in ventiquattr'ore, tutti identici: la pagina degli eventi non serviva più a niente, perché una riga nuova sarebbe finita sepolta. Mille volte lo stesso fatto e' un fatto che dura, non mille fatti, ed e' la stessa regola che ids_registra applica alle rilevazioni. Il riarmo esiste perché un problema che persiste non deve nemmeno sparire in silenzio
A G - 0 5	L'agente non legge il contenuto di file, traffico o messaggi	Raccoglie misure e fatti (chi ha effettuato l'accesso, quale processo ascolta): il contenuto è dato personale altrui e non serve a nessuna delle regole

I valori più lunghi di quanto la colonna possa contenere sono abbreviati con i puntini (...); il dato completo resta nell'inventario della console.

4. Architettura

macchina sorvegliata rete del cliente sede



apre lui apre lei risponde

Tre livelli, una regola sola: chi sta più in basso apre verso chi sta più in alto. Nessuno dei tre chiama indietro.

Il ciclo dell'IDS

Gira nel processo dell'agente della sonda (quello senza interfaccia), a cadenza dichiarata:

- 1. osserva: ogni sensore abilitato produce osservazioni dall'archivio locale;
- 2. confronta con la linea di base (che cosa era normale finora);

- 3. applica le regole: ogni regola guarda le osservazioni del proprio genere;
- 4. deduplica: la stessa rilevazione sullo stesso soggetto non si ripete, si aggiorna con il conteggio e l'ultima volta;
- 5. accoda verso il server, come qualunque altro record;
- 6. aggiorna la linea di base: ciò che è stato rilevato diventa il nuovo normale, altrimenti la stessa cosa si segnalerebbe per sempre.

4.1-bis Dove stanno i dati, e come si chiamano

Le tabelle sono due volte, una per applicativo, e non sono le stesse: sulla sonda c'è ciò che serve a rilevare (la linea di base, le rilevazioni da conferire, le macchine registrate con le loro chiavi); sul server c'è ciò che serve a guardare (le rilevazioni conferite, con tenant e nodo).

SONDA	SERVER	PERCHÉ NON È LA STESSA TABELLA
local_ids_baseline	—	La memoria di ciò che era normale non lascia mai la sonda: è grande, cambia di continuo e al server non serve
local_ids_findings	ids_findings	Sulla sonda c'è conferita_at (che cosa è già stato consegnato); sul server c'è tenant_id, il nodo, lo stato e la nota di chi ha deciso
local_agents	agent_hosts	La sonda conserva la chiave con cui l'agente firma; il server non la vede e non deve vederla
local_agent_metrics, local_agent_events	agent_metrics, agent_events	Stesso contenuto, due cicli di vita: sulla sonda si cancellano dopo il conferimento, sul server si conservano secondo la ritenzione del tenant

Il prefisso local_ non è un vezzo. Tre di queste tabelle nascevano con lo stesso nome di quelle del server pur avendo colonne diverse. In esercizio non si incontrano — due applicativi, due basi dati — ma chi le mette sullo stesso PostgreSQL (i test lo fanno) trova un CREATE TABLE IF NOT EXISTS che non crea niente, perché la tabella esiste già, e l'indice successivo che fallisce su una colonna inesistente: un guasto che non somiglia per niente alla propria causa. La convenzione era già in uso per local_nodes; adesso vale per tutte, e un test confronta i due schemi a ogni giro.

I sensori (punto d'innesto)

Un sensore è una classe con quattro cose: codice, nome, disponibile() e osserva(archivio, adesso). Il motore non sa nulla di come l'osservazione sia stata ottenuta.

SENSORE	STATO	CHE COSA VEDE
inventario	attivo	nodi, porte, MAC, ARP letto in SNMP, presenze senza fili, letture SMB — tutto ciò che la sonda già raccoglie
agenti	attivo	accessi, processi in ascolto, utenti, servizi, metriche fuori soglia riferiti dalle macchine
traffico	predisposto	pacchetti (ARP, DNS, connessioni). Richiede libpcap/Npcap e privilegi: si abilita quando quella dipendenza viene accettata

Un sensore non disponibile si dichiara nella pagina dei sensori: chi guarda deve sapere che cosa non è stato guardato, e che lo zero di quel sensore non è un "tutto a posto".

5. Catalogo delle regole (prima serie)

Ogni regola: codice, che cosa riconosce, gravità, tecnica MITRE, e il perché conta.

CODICE	RICONOSCE	GRAVITÀ	ATT&CK
ARP-MAC-CAMBIATO	Lo stesso indirizzo IP risponde con una scheda di rete diversa	alta	T1557
ARP-MAC-MULTIPLIO	Lo stesso MAC compare su molti indirizzi	media	T1557
HOST-NUOVO	Un dispositivo mai visto compare in una rete dichiarata	media	T1200
PORTA-AMMINISTRAZIONE	Compare SSH, RDP, VNC, WinRM dove non c'era	alta	T1021
PORTA-INSOLITA	Compare una porta alta non standard su un nodo stabile	media	T1571
SERVIZIO-SPARITO	Un servizio che rispondeva da settimane smette	media	T1489
SMB1-RIACCESO	Un nodo torna ad accettare il dialetto SMB 1.0	alta	T1210
WIFI-NOTTURNO	Un apparato mai visto compare sulla rete senza fili in orario di chiusura	media	T1200
ACCESSI-FALLITI	Tentativi di accesso falliti ripetuti su una macchina	alta	T1110
UTENTE-NUOVO	Un'utenza nuova, o aggiunta agli amministratori	alta	T1136
SICUREZZA-FERMA	Servizio di sicurezza (antivirus, firewall) fermo	critica	T1562
ASCOLTO-NUOVO	Un processo nuovo si mette in ascolto su una porta	alta	T1571

Le soglie e le finestre sono per tenant e modificabili: un ufficio con turni notturni e un magazzino chiuso alle 18 non hanno la stessa idea di "orario insolito".

6. L'agente di macchina

Che cosa raccoglie

GRUPPO	MISURE	A CHE COSA SERVE
Identità	nome host, sistema e versione, avvio, indirizzi	Legare la macchina al nodo dell'inventario
Carico	CPU, memoria, swap, carico medio	Vedere una macchina che soffre prima che si fermi
Dischi	spazio usato per punto di mount	Il guasto più prevedibile che esista
Rete	byte e pacchetti per interfaccia	Un salto di traffico è la prima traccia di un'esfiltrazione
Processi	quanti, e i primi per CPU e memoria	Un processo che divora la macchina ha un nome
Porte in ascolto	porta, processo, utente	La differenza fra "porta aperta" e "chi l'ha aperta"
Utenti	sessioni attive	Chi è dentro adesso
Eventi di sicurezza	accessi riusciti e falliti, utenti creati, servizi di sicurezza fermati	Le regole ACCESSI-FALLITI, UTENTE-NUOVO, SICUREZZA-FERMA
Aggiornamenti	quanti in attesa, quanti di sicurezza	La vetustà vista da dentro, non dedotta da una pagina web

Che cosa NON raccoglie, per scelta

Contenuto di file, righe di comando complete, traffico, messaggi, cronologia. Le righe di comando possono contenere password passate come argomento: si registra il nome del processo e il suo utente, non come è stato invocato.

Ciclo di vita

```
pip install psutil
python snap_agent.py registra https://sonda:5510 <token> una volta
python snap_agent.py servizio a regime
python snap_agent.py prova raccoglie e stampa, senza inviare
```

Il terzo comando esiste per chi installa: mostra esattamente ciò che verrebbe mandato, senza mandarlo. Serve a rispondere alla domanda che chiunque riceva un agente su una macchina di produzione fa per prima — che cosa mi porta via da qui?

Alla registrazione la sonda emette una chiave; l'agente la conserva in un file con permessi ristretti. A regime invia ogni intervallo secondi (predefinito 60), firmando ciascun invio. La risposta della sonda porta la configurazione: intervallo, soglie, quali gruppi raccogliere. Un agente che non riesce a parlare accumula in memoria e riprova: la rete che si interrompe non deve perdere gli eventi di sicurezza.

7. Requisiti

ID	REQUISITO
SR-300	La sonda deve eseguire un motore di rilevazione su ciò che osserva, a cadenza configurabile
SR-301	Ogni rilevazione deve dichiarare regola, gravità, soggetto, prova e istante
SR-302	La stessa rilevazione sullo stesso soggetto non deve duplicarsi: si aggiorna
SR-303	Finché la linea di base è più giovane del periodo dichiarato, le rilevazioni non devono generare allarmi
SR-304	I sensori devono essere innestabili e dichiarare la propria disponibilità
SR-305	Le rilevazioni conferite devono entrare nel SIEM come eventi normalizzati
SR-310	L'agente deve autenticarsi con chiave propria e firmare ogni invio con marca temporale e nonce
SR-311	L'agente non deve accettare comandi dalla sonda
SR-312	L'agente deve accumulare e ritrasmettere quando la sonda non risponde
SR-312-bis	Un evento che descrive una condizione persistente non deve essere ripetuto a ogni invio: si riferisce al cambiamento di stato e si riarma a intervallo dichiarato
SR-313	L'agente non deve raccogliere contenuti, ma solo misure e fatti
SR-314	La console deve mostrare rilevazioni, regole, sensori e macchine con agente, dichiarando ciò che non è stato osservato

8. Privacy e conformità

L'agente raccoglie nomi utente e sessioni: sono dati personali (GDPR art. 4). La base giuridica è la stessa dell'inventario — sicurezza della rete, art. 6(1)(f) — e le conseguenze pratiche sono tre: non si raccolgono contenuti (§6.2), la conservazione è a termine come per il resto dell'archivio, e le pagine nominano macchine e utenze, non persone.

Per NIS2 le rilevazioni sono il materiale della notifica di incidente: portano l'istante del rilevamento, il soggetto, la prova e la tecnica riconosciuta.

9. Come si legge: sei casi

I casi che seguono sono scritti nella forma in cui arrivano davanti a chi guarda: la riga che compare, la domanda che si pone, e che cosa la distingue da un falso allarme. Nessuno di essi è un esercizio: cinque sono accaduti durante il collaudo su una rete reale, il sesto è la ragione per cui l'IDS tace le prime dodici ore.

Caso 1 – La porta di amministrazione comparsa

alta · PORTA-AMMINISTRAZIONE · 10.20.14.31:3389 · T1021 amministrazione comparsa su 10.20.14.31 prova: porta 3389 dove non rispondeva (noto dal 2026-09-02 08:14)

Che cosa dice. Non "la 3389 è aperta" — questo la relazione sull'esposizione lo dice già, e su una rete grande sono decine. Dice che su quella macchina, dove per undici giorni non rispondeva, adesso risponde.

Come si decide. Due domande, in quest'ordine: qualcuno ha chiesto il desktop remoto su quella macchina? e quella macchina doveva averlo? Se la risposta alla prima è sì, si archivia con la nota «abilitato su richiesta del reparto X il 13/09» — e la nota resta, perché fra sei mesi nessuno se ne ricorderà. Se è no, è un incidente: qualcuno ha abilitato un accesso remoto senza dirlo. Il falso allarme tipico. Una macchina reinstallata. Il sistema torna con i servizi predefiniti attivi, e la 3389 ricompare per un motivo che non ha niente di malevolo. La prova lo suggerisce: se nello stesso giro compare anche ARP-MAC-CAMBIATO sullo stesso indirizzo, non è la stessa macchina di prima.

Caso 2 – Lo stesso indirizzo con una scheda di rete diversa

alta · ARP-MAC-CAMBIATO · 10.20.10.1 · T1557 10.20.10.1 risponde con una scheda di rete diversa prova: prima 00:1b:17:00:01:18, adesso 2c:21:72:5f:aa:03 (noto dal 2026-08-29)

Che cosa dice. L'indirizzo è lo stesso, il ferro no.

Come si decide. Su un gateway — e questo lo è — la faccenda è seria: è la forma che prende un attacco in mezzo alla comunicazione. Su una postazione è quasi sempre banale: una scheda sostituita, un portatile che ha preso l'indirizzo lasciato libero da un altro, una docking station cambiata. La zona del nodo è la prima cosa da guardare, e il costruttore del MAC la seconda: se il MAC nuovo appartiene a un costruttore di apparati di rete e quello vecchio a un produttore di portatili, qualcosa non torna.

Il falso allarme tipico. DHCP con lease corti e un pool piccolo: gli indirizzi girano, e la regola vede cambiare il MAC di un IP ogni pochi giorni. In una rete così, la si guarda solo nelle zone a indirizzamento statico.

Caso 3 – SMB 1.0 riaccesso

alta · SMB1-RIACCESO · 10.20.22.7 · T1210 10.20.22.7 accetta di nuovo SMB 1.0 prova: il dialetto NT LM 0.12 era assente alla lettura precedente

Che cosa dice. Un protocollo che era stato spento è tornato. È il protocollo di WannaCry: non è una regola di stile.

Come si decide. Quasi sempre c'è un colpevole innocente e noto: una stampante di rete vecchia, uno scanner che deposita su una condivisione, un gestionale che non è mai stato aggiornato. La domanda giusta non è chi lo ha riaccesso ma che cosa lo ha preteso. Si archivia con quel nome scritto nella nota, e si apre un'attività per sostituire la cosa che lo pretende.

Attenzione al confronto con la relazione SMB. Quella elenca tutte le macchine con SMB1 attivo (nel collaudo: 132). Questa ne segnala una sola: quella che l'ha riaccesso. Sono due domande diverse e servono entrambe.

Caso 4 – L'antivirus fermo, visto da dentro

critica · SICUREZZA-FERMA · ised-7007-dell-2ca964cf/Defender · T1562 nessun antivirus attivo fra i 2 registrati sensore: agenti

Che cosa dice. Dalla rete questa cosa non si vede: una macchina senza protezione risponde alle porte esattamente come una

protetta. La riferisce l'agente, ed è il motivo per cui l'agente esiste.

Come si decide. È l'unica regola di gravità critica del catalogo, e si guarda subito. Disattivare la protezione è il passo che precede quasi tutto il resto.

Il falso allarme che abbiamo trovato noi. Durante il collaudo la regola scattava su una macchina protetta: l'agente interrogava il servizio di Defender, ma su quella macchina l'antivirus era di un altro produttore e Defender era fermo perché doveva esserlo. Adesso l'agente interroga il centro sicurezza di Windows, che elenca tutti i prodotti registrati, e segnala solo se nessuno di essi risulta attivo. La lezione vale oltre il caso: una regola che guarda un prodotto invece della funzione produce allarmi su chi ha fatto la scelta giusta.

Caso 5 – Il disco che finisce

alta · genere disco_pieno · ised-7007-dell spazio quasi esaurito su C:\: 97.7% di 475.8 GB

Che cosa dice. È il guasto più prevedibile che esista, ed è la ragione per cui l'agente raccoglie i dischi: non è sicurezza, è continuità operativa — e chi guarda gli incidenti è la stessa persona.

Come si legge la ripetizione — e perché non c'è più. Nella prima versione dell'agente questo evento si ripresentava a ogni invio finché la condizione durava: centootto righe identiche in ventiquattr'ore, e la pagina degli eventi non serviva più a niente. Dalla 1.0.2 una condizione si riferisce quando cambia di fascia (il 97,8% e il 97,9% sono la stessa notizia; il 92% e il 97% no) e si riarma dopo sei ore, così un problema che dura non sparisce in silenzio (AG-06). Se la condizione rientra, l'agente se ne dimentica subito: quando risale lo dice di nuovo senza aspettare il riarmo.

Caso 6 – Il silenzio delle prime dodici ore

(nessuna rilevazione) Memoria ancora giovane. La sonda probe-office-ised conosce 9.889 soggetti da 0.2 ore.

Che cosa dice. Che il motore sta ancora imparando, e che lo zero in cima alla pagina non è una buona notizia.

Perché esiste. Alla prima passata sulla rete di collaudo l'IDS ha prodotto quattrocento rilevazioni HOST-NUOVO: era corretto — non aveva mai visto nessuno di quei nodi — ed era inutile. Quattrocento allarmi il primo giorno sono il modo più rapido per far disattivare un IDS. Da qui la regola: finché l'archivio di ciò che era normale è più giovane di dodici ore, le regole fondate sull'assenza di memoria costruiscono la linea di base e tacciono (IDS-06).

Che cosa fare nel frattempo. Niente, ma saperlo: la pagina lo dichiara in un avviso, e la colonna «memoria» della pagina dei sensori dice per ciascuna sonda a che punto è. Dopo dodici ore l'avviso sparisce da solo.

Come si usa la pagina in un turno

1. Si aprono le rilevazioni aperte, che arrivano già ordinate per gravità.
2. Per ognuna si legge la prova prima del titolo: il titolo dice che cosa, la prova dice rispetto a quando.
3. Si decide: atteso > si archivia con la nota che dice perché; non atteso > si apre un incidente dalla pagina del SIEM, dove la stessa rilevazione è già arrivata come evento.
4. Prima di chiudere il turno con zero rilevazioni si guarda Regole e sensori: se due sensori su tre non stanno osservando, quello zero non significa quello che sembra.

10. Limiti dichiarati

- Nessuna ispezione del traffico (§1.1): niente firme su payload, C2 cifrato, esfiltrazione.
- Il sensore d'inventario vede quanto spesso la sonda guarda: fra due passate un cambiamento passa inosservato. Le cadenze sono dichiarate nella console.
- L'agente vede una macchina sola: una compromissione che non tocca né i suoi processi né i suoi accessi non lascia tracce per lui.
- La linea di base impara ciò che trova: se una porta di amministrazione era già aperta al primo giro, per l'IDS è normale. La relazione sull'esposizione, che invece la segnala sempre, resta il posto dove guardare per quello.